

BDAS-Plattform — Datenschutz-Bestandsaufnahme

Technische Grundlage für die Erstellung der Datenschutzerklärung · Stand: 9. August 2026 · Erstellt aus dem Quellcode der Plattform (Repository `Bdas_website`, Branch `main`)

Zweck und Grenzen dieses Dokuments

Dieses Dokument beschreibt **vollständig und faktenbasiert, welche personenbezogenen Daten die BDAS-Plattform tatsächlich verarbeitet**, wo sie liegen, wer sie sieht, an wen sie fließen und wie lange sie gespeichert bleiben. Es ist als Arbeitsgrundlage für eine Datenschutzespezialistin bzw. einen Datenschutzespezialisten gedacht, die bzw. der daraus die Datenschutzerklärung und das Verzeichnis von Verarbeitungstätigkeiten (Art. 30 DSGVO) erstellt.

Alle Angaben sind aus dem Quellcode abgeleitet (Datenbankschemata, Migrationen, Formulare, externe Aufrufe) und mit Dateipfaden belegt. **Es handelt sich nicht um eine Rechtsberatung.** Vorschläge zu Rechtsgrundlagen sind als Diskussionsangebot gekennzeichnet und ausdrücklich zu prüfen. Angaben, die sich nicht aus dem Code ergeben (Vertragslage mit Dienstleistern, Serverstandorte in den Anbieter-Konten, Identität des Verantwortlichen), sind als **offen** markiert.

1. Die Plattform in Kürze

2. Verantwortlicher — offene Angaben

3. Verarbeitete Datenkategorien im Detail

4. Verarbeitungszwecke und Rechtsgrundlagen (Vorschlag)

5. Empfänger und Auftragsverarbeiter

6. Dritt-Inhalte im Browser der Nutzenden

7. Cookies und lokale Speicherung
8. Sichtbarkeit und Zugriffsrechte innerhalb der Plattform

9. Betroffenenrechte — Ist-Stand der Umsetzung

10. Speicherdauer und Löschkonzept

11. Technische und organisatorische Maßnahmen

12. Geplante, noch nicht umgesetzte Verarbeitungen

13. Offene Punkte und Fragen

14. Anhang: vollständiges Tabellenverzeichnis

1. Die Plattform in Kürze

Die BDAS-Plattform ist eine einzelne Webanwendung (Next.js 14, TypeScript), die sowohl den öffentlichen Webauftritt als auch den geschlossenen Mitglieder- und Vorstandsbereich des Verbands abbildet. Sie ersetzt die bisherige WordPress-Installation. Der Zugang zum geschlossenen Bereich erfolgt über ein eigenes Konto mit E-Mail-Adresse und Passwort.

Baustein	Technologie	Datenschutzrelevanz
Anwendung / Hosting	Next.js 14 auf Vercel	Verarbeitet jede Anfrage; Server-Logs des Hosters (IP-Adresse, Zeitstempel, angefragte URL) liegen beim Anbieter. Die Ausführungsregion ist im Code nicht festgelegt (<code>vercel.json</code> enthält keine <code>regions</code> - Angabe) — offen
Datenbank	PostgreSQL bei Supabase (Drizzle ORM)	Speichert sämtliche im Abschnitt 3 aufgeführten Daten
Dateispeicher	Supabase Storage (Objektspeicher)	Vier Buckets: <code>files</code> (privat, Verbandsdokumente), <code>profile-media</code> (privat, Profilfotos), <code>event-media</code> (öffentlich, Veranstaltungsbilder), Content-Medien (öffentlich, Seitenbilder)

Baustein	Technologie	Datenschutzrelevanz
E-Mail-Versand	Resend	Erhält Empfänger-E-Mail-Adresse, Name und Inhalt jeder transaktionalen E-Mail
Sitzungsverwaltung	Eigenentwicklung: Argon2-Passworthash, HS256-JWT im Cookie	Ein einziges, technisch notwendiges Cookie (Abschnitt 7)
Web-Analyse / Tracking	—	Nicht vorhanden Kein Analyse-Werkzeug, kein Werbe-Pixel, kein Consent-Management-Tool, keine externen Schriftarten im Code auffindbar
Zahlungen	—	Noch nicht umgesetzt Stripe ist in der Architektur vorgesehen, es existiert jedoch kein Code und keine Datenverarbeitung (Abschnitt 12)

Funktionsmodule

Die Plattform ist in Module aufgeteilt, die einzeln über Umgebungsvariablen (`BDAS_FLAG_<NAME>`) an- und abschaltbar sind. Ein abgeschaltetes Modul verarbeitet keine Daten. Vorhanden sind: `auth` (Konten), `members` (Mitgliedschaft und Rollen), `profile` (Mitgliedsprofil), `groups` (Hochschulgruppen), `events` (Veranstaltungen), `files` (Dateiablage), `notifications` (E-Mails), `blog`, `projects`, `content` (redaktionelle Seiten), `dashboard`, `public_shell`, `group_map`, `handover`, `payments`.

Welche Module im Produktivbetrieb aktuell eingeschaltet sind, ergibt sich aus den Umgebungsvariablen der Produktivumgebung und ist vor Veröffentlichung der Datenschutzerklärung abzugleichen. **offen**

2. Verantwortlicher — offene Angaben

Die folgenden Angaben ergeben sich nicht aus dem Quellcode und müssen vom Verband beigebracht werden. Sie sind für die Datenschutzerklärung zwingend erforderlich:

- **Verantwortlicher im Sinne des Art. 4 Nr. 7 DSGVO:** vollständiger Name des Vereins, Rechtsform, Anschrift, Registergericht und Registernummer, Vertretungsberechtigte
- **Kontaktdaten für Datenschutzanfragen:** E-Mail-Adresse und Postanschrift
- **Datenschutzbeauftragte(r):** ob ein solcher bestellt ist bzw. bestellt werden muss (§ 38 BDSG — regelmäßig mindestens 20 Personen, die ständig mit automatisierter Verarbeitung beschäftigt sind), und falls ja: Kontaktdaten
- **Verhältnis Bundesverband ↔ Hochschulgruppen:** Die Plattform bildet Hochschulgruppen mit eigenen Vorständen ab, die Zugriff auf die Daten ihrer Gruppenmitglieder haben (Abschnitt 8). Ob dies eine gemeinsame Verantwortlichkeit (Art. 26 DSGVO) begründet oder die Gruppen rechtlich unselbständige Untergliederungen des Verbands sind, ist die zentrale offene Frage dieser Bestandsaufnahme.
- **Aufsichtsbehörde** für die Beschwerdebelehrung (abhängig vom Sitz des Verbands)

3. Verarbeitete Datenkategorien im Detail

Nachfolgend jede Datenkategorie, die die Plattform speichert, mit der zugehörigen Datenbanktabelle, dem Zeitpunkt der Erhebung und der Quelle der Daten.

3.1 Kontodaten (Modul `auth`)

Tabelle	Felder	Erhebung / Anmerkung
<code>auth_users</code>	ID, E-Mail-Adresse (normalisiert und in Anzeigeform), Status, Zeitpunkt und Version der Einwilligung in die Datenschutzerklärung, Erst- und Änderungszeitpunkt	Bei der Registrierung durch die betroffene Person selbst
<code>auth_credentials</code>	Passwort-Hash, verwendetes Hash-Verfahren, Änderungszeitpunkt	Das Passwort wird nicht im Klartext gespeichert , sondern ausschließlich als Argon2-Hash (Bibliothek <code>@node-rs/argon2</code>)
<code>auth_sessions</code>	Sitzungs-ID, Nutzer-ID, Ablaufzeitpunkt, Widerrufszeitpunkt, IP-Adresse, User-Agent (Browser-/Geräteerkennung), Erstzeitpunkt	Bei jedem Login. IP-Adresse und User-Agent werden im Klartext gespeichert (<code>apps/web/app/anmelden/actions.ts</code> , <code>modules/auth/src/sessions.ts</code>)
<code>auth_email_verifications</code>	Einmal-Token, Nutzer-ID, Ablauf, Einlösezeitpunkt	Bei Registrierung bzw. erneutem Versand der Bestätigungsmail
<code>auth_password_resets</code>	Einmal-Token, Nutzer-ID, Ablauf, Einlösezeitpunkt	Bei Anforderung eines Passwort-Zurücksetzens
<code>auth_rate_limits</code>	Schlüssel, Zähler, Fensterbeginn, Ablauf — der Schlüssel enthält je nach Vorgang die IP-Adresse im Klartext (z. B. <code>login:ip:...</code> , <code>register:ip:...</code> , <code>reset-request:ip:...</code>) oder die E-Mail-Adresse (<code>login:email:...</code>)	Missbrauchsschutz gegen automatisiertes Ausprobieren von Passwörtern und Massenregistrierungen (<code>modules/auth/src/rate-limit.ts</code>)

3.2 Mitgliedschaftsdaten (Modul `members`)

Tabelle	Felder	Erhebung / Anmerkung
<code>members</code>	Vorname, Nachname, zugeordnete Hochschulgruppe, Status (offen / aktiv / inaktiv), Rollen, Beitrittszeitpunkt, Zeitstempel	Vor- und Nachname bei der Registrierung; Status und Gruppe durch Vorstände
<code>member_role_grants</code>	Rolle (Mitglied, Gruppenvorstand, Gruppenvorstandsvorsitz, Bundesvorstand, Alumni), Gruppenbezug, wer wann verliehen und wer wann entzogen hat	Vollständige Historie der Rollenvergaben, einschließlich der Identität der handelnden Vorstandsperson
<code>member_group_change_requests</code>	Mitglied, Herkunfts- und Zielgruppe, Status, Zeitpunkt der Beantragung und der Entscheidung, entscheidende Person, Ablehnungsgrund (Kategorie und Freitextbegründung)	Bildet Aufnahmeanträge und Gruppenwechsel ab. Der Freitext einer Ablehnung kann beliebige Angaben zur Person enthalten und ist damit besonders sensibel

3.3 Profildaten (Modul `profile`)

Tabelle	Felder	Erhebung / Anmerkung
<code>member_profiles</code>	Studiengang, Abschlussart, Hochschule, Geburtsdatum , „gefunden durch“, Name der empfehlenden Person, Schlüssel des Profilfotos , Fertigstellungszeitpunkt	Vom Mitglied selbst im Profil-Assistenten ausgefüllt. Das Feld „Name der empfehlenden Person“ ist ein personenbezogenes Datum einer dritten Person , die von der Erhebung nichts erfährt — hierzu ist eine Bewertung erforderlich

Das Profilfoto liegt im privaten Bucket `profile-media` und ist nur über zeitlich begrenzte, signierte Links abrufbar. Ein Foto ist ein Bildnis einer natürlichen Person; eine biometrische Verarbeitung im Sinne des Art. 9 DSGVO findet *nicht* statt (keine Gesichtserkennung, kein Abgleich).

3.4 Hochschulgruppen (Modul `groups`)

`groups` speichert Name, Kürzel, Stadt, Kontakt-E-Mail-Adresse, Instagram- und Website-Adresse sowie Status und — seit der Standort-Erweiterung — Bezeichnung, Anschrift und **Geokoordinaten** des Gruppenstandorts. Diese Daten sind überwiegend organisationsbezogen, die Kontakt-E-Mail-Adresse kann jedoch personenbezogen sein (z. B. `vorname.nachname@...`) und wird auf den **öffentlichen** Gruppenseiten und in der Gruppenkarte angezeigt.

3.5 Veranstaltungen (Modul `events`)

Tabelle	Felder	Erhebung / Anmerkung
<code>events</code>	Titel, Beschreibung (Rich-Text), Zusammenfassung, Beginn/Ende, Ort mit Anschrift und Geokoordinaten, Kapazität, Sichtbarkeit (öffentlich / Mitglieder / Gruppe), Status, Titelbild, erstellende Person	Von Gruppenvorständen bzw. Veranstaltungsorganisierenden gepflegt. Der Rich-Text kann beliebige Inhalte einschließlich Bilder und YouTube-Einbettungen enthalten (Abschnitt 6)
<code>event_registrations</code>	Veranstaltung, Mitglied <i>oder</i> Gastname und Gast-E-Mail-Adresse , Anmeldezeitpunkt, Stornierungszeitpunkt, Warteliste-Position, Storno-Token für Gäste	Gäste sind Nicht-Mitglieder ohne Konto . Für sie werden Name und E-Mail-Adresse allein zur Veranstaltungsteilnahme erhoben — eigener Informationspflichten- und Löschstatbestand
<code>event_attendance</code>	Veranstaltung, Mitglied, Teilnahme ja/nein, Zeitpunkt des Eincheckens, einscheckende Person	Anwesenheitsdaten — dokumentiert das tatsächliche Verhalten einzelner Mitglieder über die Zeit. Rechtsgrundlage und Speicherdauer sind gesondert zu bewerten

3.6 Dateiablage (Modul `files`)

Tabelle	Felder	Erhebung / Anmerkung
<code>folders</code>	Name, Sichtbarkeitsbereich (alle Mitglieder / Gruppenmitglieder / Gruppenvorstand / Bundesvorstand), Gruppenbezug, Verschachtelung bis Tiefe 5, erstellende Person	Legt fest, wer die enthaltenen Dateien sehen darf

Tabelle	Felder	Erhebung / Anmerkung
files	Dateiname, Speicherschlüssel, MIME-Typ, Größe, Status, hochladende Person , Zeitstempel	Der Inhalt der Dateien ist inhaltlich unbestimmt — Vorstände können Protokolle, Mitgliederlisten und andere personenbezogene Dokumente ablegen. Dies ist datenschutzrechtlich der risikoreichste Bereich der Plattform
file_access_log	Datei, Mitglied, Aktion (Download / Upload / Löschung), Zeitpunkt	Protokoll des Nutzungsverhaltens einzelner Mitglieder. Die Spezifikation sieht 90 Tage Aufbewahrung vor; im Code ist keine automatische Löschung umgesetzt (Abschnitt 10)

3.7 Redaktionelle Inhalte (Module `blog`, `content`, `projects`)

- `posts` : Beiträge mit Titel, Rich-Text-Inhalt, Kategorie, Sichtbarkeit (öffentlich / Mitglieder / Vorstand), **verfassende Person**, Zeitstempel und Zeitpunkt der Löschung („soft delete“ — gelöschte Beiträge bleiben in der Datenbank erhalten und werden nur ausgeblendet)
- `post_reports` : Meldungen zu Beiträgen mit **meldender Person**, Freitext-Begründung und Status — enthält typischerweise Aussagen über das Verhalten einer anderen Person
- `content_pages` : redaktionelle Seiten (auch Impressum und Datenschutzerklärung selbst) mit Inhalt und der zuletzt bearbeitenden Person
- `projects` : Projekte einer Gruppe mit Titel, Beschreibung, Kontaktangabe, verknüpften Dateien und erstellender Person

3.8 E-Mail-Protokoll (Modul `notifications`)

`notification_log` speichert für **jede versendete E-Mail**: Empfänger (Mitglied oder Gast), Kanal, Vorlage, **Empfänger-E-Mail-Adresse**, Betreff, Status (versendet / fehlgeschlagen), Fehlerdetails und Zeitpunkt. Der Nachrichtentext selbst wird nicht gespeichert, wohl aber der Betreff — der bei Veranstaltungs- und Antragsbenachrichtigungen Rückschlüsse auf den Vorgang zulässt.

Versendet werden derzeit folgende Vorlagen:

- **Veranstaltungen**: Anmeldebestätigung, Warteliste, Abmeldebestätigung, Nachrücken von der Warteliste, Änderung von Zeit oder Ort, Absage, Nachricht der Organisierenden an Angemeldete
- **Rollen**: Erteilung und Entzug der Organisationsberechtigung für Veranstaltungen
- **Mitgliedschaft**: Antrag eingegangen, Antrag angenommen, Antrag abgelehnt (einschließlich Begründung), Gruppe aufgelöst
- **Moderation**: Meldung zu einem Blogbeitrag
- **Konto** (eigener Versandweg im Modul `auth`): E-Mail-Bestätigung, Passwort zurücksetzen

4. Verarbeitungszwecke und Rechtsgrundlagen (Vorschlag)

Die folgende Zuordnung ist ein **Vorschlag zur fachlichen Prüfung**, keine rechtliche Festlegung. Insbesondere die Abgrenzung zwischen Vertragserfüllung (Art. 6 Abs. 1 lit. b DSGVO — Mitgliedschaftsverhältnis) und berechtigtem Interesse (lit. f) ist zu entscheiden; für einen Verein wird die Mitgliederverwaltung überwiegend auf lit. b bzw. die Vereinssatzung gestützt.

Zweck	Daten	Rechtsgrundlage — Vorschlag
Bereitstellung der Website	Server-Logs des Hosters, IP-Adresse	Art. 6 Abs. 1 lit. f — berechtigtes Interesse am sicheren Betrieb
Kontoerstellung und Anmeldung	E-Mail, Passwort-Hash, Sitzungsdaten inkl. IP und User-Agent	Art. 6 Abs. 1 lit. b — Durchführung des Nutzungsverhältnisses
Missbrauchsschutz (Rate Limiting)	IP-Adresse, E-Mail-Adresse, Zähler	Art. 6 Abs. 1 lit. f — Sicherheit der Verarbeitung, vgl. Art. 32
Aufnahme in den Verband, Mitgliederverwaltung	Name, Gruppe, Status, Rollen, Anträge und Ablehnungsgründe	Art. 6 Abs. 1 lit. b bzw. Vereinsmitgliedschaft
Mitgliedsprofil (Studium, Geburtsdatum, Foto)	member_profiles	Prüfen: teils Vertragserfüllung, teils Einwilligung (insbesondere Foto und „Empfeher:in“) — die Felder sind derzeit technisch als Pflichtfelder ausgeführt
Veranstaltungsorganisation (Mitglieder)	Anmeldungen, Warteliste, Anwesenheit	Art. 6 Abs. 1 lit. b; Anwesenheitserfassung ggf. lit. f — gesondert zu begründen
Veranstaltungsanmeldung durch Gäste	Gastname, Gast-E-Mail-Adresse	Art. 6 Abs. 1 lit. b (vorvertraglich/Teilnahmevertrag) — eigene Informationspflicht nach Art. 13 im Anmeldeformular erforderlich
Transaktionale E-Mails	Name, E-Mail-Adresse, Vorgangsbezug	Art. 6 Abs. 1 lit. b — notwendige Begleitkommunikation, keine Werbung
Nachweis der Einwilligung in die Datenschutzerklärung	consent_at , consent_version	Art. 7 Abs. 1 — Rechenschaftspflicht
Verbandsinterne Dokumentenablage	Dateien, Zugriffsprotokoll	Art. 6 Abs. 1 lit. b/f — Zugriffsprotokoll als Sicherheitsmaßnahme (Art. 32) zu begründen und zu befristen
Redaktionelle Inhalte und Autorennennung	Beiträge, verfassende Person	Art. 6 Abs. 1 lit. f — Transparenz der Verbandskommunikation

5. Empfänger und Auftragsverarbeiter

Für alle nachfolgenden Dienstleister ist ein Auftragsverarbeitungsvertrag nach Art. 28 DSGVO erforderlich; das Vorliegen ist zu prüfen und zu dokumentieren.

Dienst	Rolle	Übermittelte Daten	Status / zu klären
Vercel	Hosting der Anwendung	Alle Anfragedaten: IP-Adresse, User-Agent, aufgerufene URL, Formularinhalte im Durchlauf, Session-Cookie	offen AVV, Ausführungsregion der Funktionen, Standardvertragsklauseln bzw. EU-US Data Privacy Framework. Im Code ist keine Region festgelegt — die Voreinstellung des Anbieters ist zu prüfen und auf die EU zu setzen
Supabase	Datenbank und Dateispeicher	Sämtliche in Abschnitt 3 genannten Daten sowie alle hochgeladenen Dateien	offen AVV, Projektregion (EU?), Aufbewahrung der Sicherungskopien seitens des Anbieters
Resend	E-Mail-Versand	Empfänger-Adresse, Name, Betreff und vollständiger Inhalt jeder transaktionalen E-Mail	offen AVV, Verarbeitungsregion, Speicherdauer der Zustellprotokolle beim Anbieter
Cloudflare R2	Aufbewahrung von Datenbanksicherungen	Vollständige Datenbankabzüge	Beschlossen, aber nicht implementiert Im Code existiert keine Sicherungsautomatisierung. Sofern Sicherungen tatsächlich angelegt werden, ist der Dienst aufzunehmen
GitHub / Vercel-Build	Entwicklung und Auslieferung	Kein Zugriff auf Produktivdaten im Regelbetrieb	Zu prüfen: Zugriffe von Entwicklerinnen und Entwicklern auf die Produktivdatenbank (technische Administration) — im Verzeichnis als interner Empfängerkreis zu führen

6. Dritt-Inhalte im Browser der Nutzenden

Diese Aufrufe erfolgen **direkt aus dem Browser der Besucherinnen und Besucher**. Dabei wird deren IP-Adresse zwangsläufig an den jeweiligen Anbieter übermittelt — auch ohne Cookie. Sie sind in der Datenschutzerklärung zu benennen.

Dienst	Wo	Was übermittelt wird / Bewertung
OpenStreetMap tile.openstreetmap.org	Kartenanzeige der Hochschulgruppen (apps/web/app/_groups/GroupMap.tsx , Leaflet)	IP-Adresse, User-Agent, angefragter Kartenausschnitt. Betreiber ist die OpenStreetMap Foundation (Vereinigtes Königreich → Drittland mit Angemessenheitsbeschluss). Die Karte lädt beim Seitenaufruf ohne weitere Interaktion — eine Zwei-Klick-Lösung wäre die datensparsamere Variante
Photon (Komoot) photon.komoot.io	Adresssuche beim Anlegen von Veranstaltungs- und Gruppenstandorten (apps/web/app/lib/photon.ts , clientseitig)	IP-Adresse und der eingegebene Suchbegriff . Betrifft nur eingeloggte Vorstände und Organisierende, nicht die Öffentlichkeit. Anbieter: komoot GmbH, Deutschland

Dienst	Wo	Was übermittelt wird / Bewertung
YouTube (Google)	Optionale Video-Einbettung im Rich-Text-Editor für Veranstaltungs- und Blogbeiträge (Tiptap-Erweiterung <code>extension-youtube</code>)	Sobald ein Redaktionsmitglied ein Video einbettet, lädt die Seite Inhalte von Google. Hier greift die Einwilligungspflicht nach § 25 TTDSG , da YouTube Cookies bzw. lokale Speicherung setzt. Zu klären: ob die Funktion genutzt wird, ob auf <code>youtube-nocookie.com</code> umgestellt und ob eine Zwei-Klick-Lösung ergänzt wird
Google Maps	Veranstaltungsseite (<code>apps/web/app/events/[id]/page.tsx</code>)	Nur ein Hyperlink zur Kartensuche, keine Einbettung. Datenübermittlung erst nach aktivem Klick — unkritisch, aber erwähnenswert
Instagram, bdaj.de, alevi.com	Fußzeile des öffentlichen Bereichs	Reine Hyperlinks, keine Einbettung, kein Social-Media-Plugin
Schriftarten, Analyse, Werbung	—	Keine externen Aufrufe Es sind keine Google Fonts, keine Analysewerkzeuge und keine Werbenetzwerke eingebunden

7. Cookies und lokale Speicherung

Bezeichnung	Art	Laufzeit	Zweck und Eigenschaften
<code>bdas_session</code>	Cookie (Erstanbieter)	7 Tage	Angemeldet-Bleiben. Enthält ein signiertes JWT (HS256). <code>HttpOnly</code> (für JavaScript nicht lesbar), <code>SameSite=Lax</code> , <code>Secure</code> im Produktivbetrieb, <code>Path=/</code> . Technisch notwendig
<code>bdas-cookie-notice</code>	localStorage	unbegrenzt, lokal	Merkt sich, dass der Cookie-Hinweis weggeklickt wurde. Verlässt das Gerät nicht

Die Plattform zeigt einen **informativen Cookie-Hinweis, kein Consent-Banner**. Begründung der Architekturentscheidung (ADR 0008): Da ausschließlich ein technisch notwendiges Cookie gesetzt wird, verlangt § 25 Abs. 2 TTDSG Information, aber keine vorherige Einwilligung; ein Ablehnen-Knopf wäre funktionslos, weil das Cookie für die Anmeldung unverzichtbar ist. Der Hinweis-Baustein ist so gebaut, dass er zu einem echten Consent-Banner ausgebaut werden kann.

Zu prüfen

Diese Begründung trägt nur, solange keine YouTube-Videos eingebettet werden. Wird die Einbettungsfunktion genutzt, entsteht eine Einwilligungspflicht — dann ist der Hinweis zum Consent-Banner auszubauen oder die Funktion abzuschalten.

8. Sichtbarkeit und Zugriffsrechte innerhalb der Plattform

Für die Datenschutzerklärung ist wesentlich, wer welche Daten sehen kann. Die Plattform unterscheidet fünf Rollen: Mitglied, Gruppenvorstand, Gruppenvorstandsvorsitz, Bundesvorstand und Alumni. Rollen sind **gruppenbezogen**: ein Gruppenvorstand sieht ausschließlich die eigene Gruppe.

Daten	Sichtbar für
Name und Gruppenzugehörigkeit	Mitglieder der eigenen Gruppe, Gruppenvorstand, Bundesvorstand
Profildaten (Studium, Geburtsdatum, Foto)	Die Person selbst, der Vorstand der eigenen Gruppe, der Bundesvorstand — der genaue Umfang je Rolle ist mit dem Verband zu bestätigen
Aufnahmeanträge einschließlich Ablehnungsgrund	Vorstand der Zielgruppe, Bundesvorstand
Veranstaltungsanmeldungen (Teilnehmendenliste)	Organisierende der Veranstaltung, Gruppenvorstand
Dateien	Je Ordner-Sichtbarkeit: alle Mitglieder / Mitglieder einer Gruppe / Gruppenvorstand / Bundesvorstand
Zugriffsprotokoll der Dateien	Vorstandsrollen (Verhaltensdaten einzelner Mitglieder)
Blogbeiträge	Je Beitrag: öffentlich / alle Mitglieder / Vorstand
Öffentlich sichtbar ohne Anmeldung	Gruppenseiten mit Kontakt-E-Mail und Standort, öffentliche Veranstaltungen mit Ort und Zeit, öffentliche Blogbeiträge mit Autorennennung, redaktionelle Seiten

9. Betroffenenrechte – Ist-Stand der Umsetzung

Recht	Status	Umsetzung in der Plattform
Auskunft (Art. 15) und Datenübertragbarkeit (Art. 20)	teilweise	Selbstbedienung unter <code>/account/datenexport</code> – JSON-Download der eigenen Daten. Abgedeckt sind derzeit nur Konto, Mitgliedsdaten, Rollen und Profil. Nicht enthalten: Veranstaltungsanmeldungen und Anwesenheit, Dateien und Zugriffsprotokoll, Blogbeiträge und Meldungen, E-Mail-Protokoll, Sitzungsdaten, Gruppenwechselanträge. Der Export weist im Text auf seine Unvollständigkeit hin. Anfragen nach Art. 15 müssen daher derzeit manuell ergänzt werden
Berichtigung (Art. 16)	umgesetzt	Profil- und Kontodaten sind unter <code>/account</code> selbst bearbeitbar
Löschung (Art. 17)	nicht umgesetzt	Es gibt keine Selbstbedienungs-Löschung und kein automatisiertes Lösungsverfahren . Die Spezifikation sieht eine Löschung mit modulübergreifender Kaskade binnen 30 Tagen vor; sie ist ausdrücklich auf eine spätere Phase verschoben (ADR 0008). Technisch sind die Fremdschlüssel überwiegend mit <code>ON DELETE CASCADE</code> ausgestattet, sodass eine manuelle Löschung des Kontos die abhängigen Datensätze mitnimmt – ausgenommen u. a. Blogbeiträge und Ordner, die nur die Urheberkennung verlieren, sowie Gast-Anmeldungen ohne Konto. Bis zur Umsetzung ist ein dokumentierter manueller Prozess erforderlich
Einschränkung (Art. 18), Widerspruch (Art. 21)	nicht umgesetzt	Nur manuell durch Administration; kein Sperrkennzeichen im Datenmodell
Widerruf der Einwilligung (Art. 7 Abs. 3)	teilweise	Die Einwilligung in die Datenschutzerklärung wird mit Zeitpunkt und Version protokolliert (aktuelle Version: <code>2026-05-18</code>). Ein Widerrufsweg in der Oberfläche existiert nicht
Benachrichtigung bei Datenpanne (Art. 33/34)	offen	Kein dokumentierter Meldeprozess im Repository – organisatorisch festzulegen

10. Speicherdauer und Löschkonzept

Kernbefund

Die Plattform hat derzeit **kein umgesetztes Löschkonzept**. Der einzige automatisierte Aufräumvorgang ist ein täglicher Lauf um 03:00 Uhr, der abgebrochene Datei-Uploads älter als 24 Stunden entfernt (`/api/cron/files-sweep`). Alle übrigen Daten bleiben unbefristet gespeichert. Das betrifft insbesondere Daten mit IP-Bezug und Verhaltensdaten.

Daten	Ist-Zustand	Empfehlung zur Festlegung
Abgelaufene Sitzungen inkl. IP und User-Agent	unbegrenzt Ablaufzeitpunkt vorhanden, aber keine Löschung der Zeilen	Löschung kurz nach Ablauf, z. B. 7–30 Tage
Bestätigungs- und Passwort-Reset-Token	unbegrenzt	Löschung nach Einlösung bzw. Ablauf
Rate-Limit-Einträge mit IP-Adresse	unbegrenzt trotz Ablauffeld	Löschung nach Fensterablauf (Stunden)
Zugriffsprotokoll Dateien	unbegrenzt — die Spezifikation nennt 90 Tage, im Code nicht umgesetzt	90 Tage, automatisiert
E-Mail-Protokoll (Adresse und Betreff)	unbegrenzt	Kurz (z. B. 30–90 Tage) oder Anonymisierung nach Zustellnachweis
Gast-Anmeldungen zu Veranstaltungen	unbegrenzt	Löschung nach der Veranstaltung, z. B. nach 30–90 Tagen
Anwesenheitsdaten	unbegrenzt	Frist festlegen; ohne Zweck zeitnah löschen
Gelöschte Blogbeiträge	verbleiben — nur als gelöscht markiert („soft delete“)	Endgültige Löschung nach Frist
Daten ausgetretener Mitglieder	unbegrenzt	Regelfrist festlegen; steuer- und vereinsrechtliche Aufbewahrungspflichten (z. B. Beitragsunterlagen) berücksichtigen
Abgebrochene Uploads	24 Stunden	—
Server-Logs und Sicherungen der Dienstleister	offen	Bei Vercel, Supabase und Resend erfragen und in die Erklärung übernehmen

11. Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

Umgesetzt

- **Passwortschutz:** Speicherung ausschließlich als Argon2-Hash; das verwendete Verfahren wird je Datensatz mitgeführt, sodass eine Umstellung möglich bleibt
- **Sitzungen:** signiertes JWT in einem `HttpOnly`-Cookie, damit für Skripte im Browser unzugänglich; `SameSite=Lax` gegen Cross-Site-Request-Forgery; `Secure` im Produktivbetrieb; Sitzungen sind widerrufbar; bei Passwortänderung wird die Sitzung erneuert
- **Missbrauchsschutz:** Ratenbegrenzung für Anmeldung, Registrierung und Passwort-Zurücksetzen, jeweils nach IP-Adresse und E-Mail-Adresse
- **Kontenbestätigung:** Registrierung erfordert die Bestätigung der E-Mail-Adresse über einen einmaligen, ablaufenden Link
- **Rollen- und Sichtbarkeitsmodell:** gruppenbezogene Rollen mit vollständiger Vergabe-Historie; Ordner- und Beitragssichtbarkeiten (Abschnitt 8); Berechtigungsprüfung erfolgt serverseitig
- **Row Level Security** (zeilenbasierter Zugriffsschutz in der Datenbank) ist in den Migrationen für die Tabellen `files`, `folders`, `file_access_log`, `content_pages`, `member_profiles` und `member_group_change_requests` aktiviert
- **Dateiablage:** privater Bucket, Zugriff ausschließlich über zeitlich begrenzte signierte Links; Prüfung von Dateityp und -größe; Protokollierung jedes Zugriffs
- **Datenexport** ist streng auf die anfragende Person beschränkt — es gibt keinen Parameter, über den fremde Daten abgerufen werden könnten
- **Transportverschlüsselung** durchgängig über HTTPS (Vercel), Datenbank- und Speicherzugriff über TLS
- **Entwicklungsprozess:** automatisierte Tests, Code-Review-Pflicht, Sicherheitsreview für Änderungen an Authentifizierung, Zahlungen und Dateien; Module hinter Schaltern, sodass unfertige Funktionen keine Daten verarbeiten

Zu prüfen oder offen

- **offen** **Tatsächlicher Aktivierungszustand von Row Level Security in der Produktivdatenbank** — der Anwendungszugriff läuft über eine privilegierte Verbindung, sodass ein Fehler in der Anwendungslogik nicht auf Datenbankebene aufgefangen würde. Vor Freigabe der Dateiablage für echte Dokumente zu verifizieren
- **offen** **Zwei-Faktor-Authentisierung** ist nicht vorhanden — auch nicht für Vorstandskonten, die Zugriff auf Mitgliederdaten haben
- **offen** **Datensicherung:** Über die vom Anbieter bereitgestellten Sicherungen hinaus ist keine eigene Sicherungsroutine umgesetzt; ein Wiederherstellungstest ist nicht dokumentiert
- **offen** **Löschroutinen** (Abschnitt 10)
- **offen** **Zugriff der administrierenden Personen** auf die Produktivdatenbank: Kreis der Berechtigten, Verpflichtung auf Vertraulichkeit, Protokollierung
- **offen** **Schulung und Verpflichtung der Vorstände**, die über die Plattform auf Mitgliederdaten zugreifen

12. Geplante, noch nicht umgesetzte Verarbeitungen

Diese Punkte sind in Spezifikation oder Architekturentscheidungen vorgesehen, verarbeiten derzeit aber **keine** Daten. Sie sollten bei der Gestaltung der Datenschutzerklärung mitgedacht werden, damit sie später nicht zu einer Neufassung zwingen:

- **Mitgliedsbeiträge über Stripe** — Zahlungsdaten, Beitragshistorie, steuerrechtliche Aufbewahrungsfristen. Es existiert kein Code
- **Kontolöschung mit 30-Tage-Kaskade** über alle Module
- **Erweiterung des Datenexports** um Veranstaltungen, Dateien, Blog und E-Mail-Protokoll
- **Newsletter bzw. Rundmails** und Benachrichtigungseinstellungen — derzeit werden ausschließlich transaktionale E-Mails versendet, es gibt kein Abmelde-Verfahren, weil es keine Werbe-E-Mails gibt
- **Gruppenbezogene Absenderadressen** für E-Mails
- **Web-Analyse** — nicht vorhanden; bei Einführung wird der Cookie-Hinweis einwilligungspflichtig

13. Offene Punkte und Fragen

Checkliste für das Gespräch mit der Datenschutzspezialistin bzw. dem Datenschutzspezialisten:

1. **Verantwortlichkeit:** Sind die Hochschulgruppen unselbstständige Untergliederungen oder eigene Verantwortliche? Braucht es eine Vereinbarung nach Art. 26 DSGVO?
2. **Rechtsgrundlage für die Profilpflichtfelder:** Sind Geburtsdatum, Studiengang und Hochschule als Pflichtangaben erforderlich, oder ist eine Einwilligungslösung mit Freiwilligkeit vorzuziehen?
3. **Profilfoto:** Einwilligung erforderlich? Wer darf es sehen? Wie erfolgt der Widerruf?
4. **Feld „empfehlende Person“:** Erhebung von Daten Dritter — Informationspflicht nach Art. 14 DSGVO?
5. **Ablehnungsbegründungen** für Aufnahmeanträge: Speicherdauer und Zugriffskreis, da Freitext über eine Person
6. **Anwesenheitserfassung** bei Veranstaltungen: Zweck, Rechtsgrundlage, Löschfrist
7. **Zugriffsprotokoll der Dateiablage:** als Sicherheitsmaßnahme begründbar? Wer darf es einsehen? Mitbestimmungähnliche Bedenken bei Verhaltensdaten Ehrenamtlicher
8. **Gäste bei Veranstaltungen:** eigener Datenschutzhinweis im Anmeldeformular, Löschfrist
9. **YouTube-Einbettung:** abschalten, auf die cookiefreie Variante umstellen oder Consent-Banner einführen?
10. **Kartenanzeige:** OpenStreetMap direkt laden oder Zwei-Klick-Lösung?
11. **Serverstandorte** von Vercel, Supabase und Resend: EU-Region bestätigen bzw. umstellen; Drittlandtransfer und Standardvertragsklauseln dokumentieren
12. **Auftragsverarbeitungsverträge** mit Vercel, Supabase und Resend abschließen bzw. nachweisen
13. **Löschkonzept** mit konkreten Fristen je Datenart festlegen (Abschnitt 10) — anschließend technisch umsetzen
14. **Löschverfahren für Konten:** Bis zur technischen Umsetzung ein dokumentierter manueller Ablauf inklusive Nachweis
15. **Vollständigkeit des Datenexports:** reicht der derzeitige Umfang für Art. 15, oder muss vor dem Start nachgebessert werden?
16. **Verzeichnis von Verarbeitungstätigkeiten** (Art. 30) — dieses Dokument kann als Grundlage dienen
17. **Datenschutzbeauftragte(r):** Bestellpflicht prüfen
18. **Verpflichtung und Schulung der Vorstände,** die Mitgliederdaten einsehen
19. **Meldeprozess für Datenschutzverletzungen** festlegen

20. **Einwilligungsversion:** Bei Inkrafttreten der neuen Datenschutzerklärung ist die Versionskennung im Code zu erhöhen; zu klären, ob bestehende Konten erneut zustimmen müssen

14. Anhang: vollständiges Tabellenverzeichnis

Alle Datenbanktabellen der Plattform mit Personenbezug. Grundlage: die Migrationsdateien unter `modules/<modul>/migrations/`.

Tabelle	Modul	Personenbezug	Inhalt in Stichworten
<code>auth_users</code>	auth	direkt	E-Mail, Status, Einwilligung
<code>auth_credentials</code>	auth	direkt	Passwort-Hash
<code>auth_sessions</code>	auth	direkt	Sitzungen, IP-Adresse, User-Agent
<code>auth_email_verifications</code>	auth	indirekt	Bestätigungstoken
<code>auth_password_resets</code>	auth	indirekt	Reset-Token
<code>auth_rate_limits</code>	auth	direkt	IP-Adresse bzw. E-Mail im Schlüssel
<code>members</code>	members	direkt	Name, Gruppe, Status, Rollen
<code>member_role_grants</code>	members	direkt	Rollenhistorie mit handelnden Personen
<code>member_group_change_requests</code>	members	direkt	Anträge, Entscheidungen, Ablehnungsgründe
<code>member_profiles</code>	profile	direkt	Studium, Geburtsdatum, Foto, Empfehler:in
<code>groups</code>	groups	möglich	Gruppendaten, Kontakt-E-Mail, Standort
<code>events</code>	events	indirekt	Veranstaltungen, erstellende Person
<code>event_registrations</code>	events	direkt	Anmeldungen von Mitgliedern und Gästen
<code>event_attendance</code>	events	direkt	Anwesenheit, Check-in
<code>folders</code>	files	indirekt	Ordner mit Sichtbarkeitsbereich
<code>files</code>	files	direkt / Inhalt	Dateien und hochladende Person
<code>file_access_log</code>	files	direkt	Zugriffsprotokoll je Mitglied
<code>notification_log</code>	notifications	direkt	Empfängeradresse, Betreff, Status
<code>posts</code>	blog	indirekt	Beiträge, verfassende Person, Soft-Delete
<code>post_reports</code>	blog	direkt	Meldungen mit meldender Person und Begründung
<code>projects</code>	projects	indirekt	Projekte, Kontakt, erstellende Person
<code>content_pages</code>	content	indirekt	Redaktionsseiten, bearbeitende Person

Erstellt am 9. August 2026 auf Grundlage des Repository-Standes des Branches `main`. Bei Änderungen an Datenmodell, Dienstleistern oder eingebundenen Dritt-Inhalten ist dieses Dokument fortzuschreiben.